

排班系統後端技術教學

從 Spring Boot API 到資料一致性與 JWT 安全設計

本教材對應目前專案的 backend

原始碼，目標是讓你能在面試中解釋「為什麼這樣設計」，也能自己修改功能。

1. 後端技術地圖

層次	技術	責任
Web API	Spring Boot 4.1.1 / MVC	接收 HTTP、驗證輸入、回傳 JSON
商業邏輯	Service + @Transactional	集中排班規則與交易邊界
資料存取	Spring Data JPA	Repository 封裝查詢
資料庫	PostgreSQL	約束、索引、交易一致性
版本管理	Flyway	用 migration 建立可重現 schema
安全	Spring Security + OAuth2 Resource Server	驗證 JWT、轉換角色權限

建議理解順序：先看 Controller 找到 API，再進 Service 看規則，最後看 Repository 與 migration 如何落地。

2. Spring Boot 專案結構

啟動類別建立 Spring Application Context。標記為 @RestController 的類別處理 HTTP，@Service 類別放商業邏輯，Repository 由 Spring Data 產生實作。這種分層讓測試可以直接針對 service，不必透過瀏覽器。

```
src/main/java/com/example/scheduling
auth/          ■■■■access token■■■■refresh token
schedule/      ■■ API■■Service■■Entity■■Repository
calendar/      ■■■■■■■■■■
report/        ■■■■■■■■
config/        Security■■CORS■■■■■■■
user/          ■■■ Entity ■ Repository
```

3. API 的完整生命週期

以員工提交班表為例：HTTP request 先進入 Controller，@Valid 驗證格式，再呼叫 Service。Service 檢查月份、日期、員工身份與容量，Repository 查詢 / 寫入 PostgreSQL，最後由 Controller 回傳 MonthView。

```
@PostMapping("/api/schedules/month")
public MonthView replace(@AuthenticationPrincipal Jwt jwt,
    @Valid @RequestBody UpdateRequest request) {
    return service.replaceMonth(jwt.getSubject(),
        request.month(), request.dates());
}
```

Controller 應該薄：它負責 HTTP 邊界。規則集中在 ScheduleService，避免同一規則散落在多個 endpoint。

4. 排班規則與交易鎖

replaceMonth() 使用 @Transactional，代表刪除舊班表、重新計算容量與寫入新班表會在同一個交易內完成。days.lockMonth(start, end) 先鎖定指定月份的 calendar

rows，讓同一時間提交的請求依序取得鎖，避免兩個請求同時看到相同的剩餘容量。

```
1. TreeSet ■■■■■■
2. ■■ 6 ■ 15 ■
3. ■■■■■■■■■■■■
4. ■■■■ calendar_days
5. ■■■■■■■■■■■■ 2 ■
6. delete ■■■■ saveAll ■■■■
```

資料庫的 UNIQUE(employee_id, work_date) 是第二道防線。即使程式未來出現 bug，也不能讓同一員工同一天重複排班。

5. JWT、Refresh Token、安全與角色

登入成功後，後端回傳短效 access token，並以 HttpOnly、SameSite=Strict cookie 保存 refresh token。前端只把 access token 放在記憶體，過期時呼叫 /api/auth/refresh。RefreshTokenService 會 rotate token；若偵測到已被取代的 token 重用，便撤銷整個 family，降低 token 被竊取後的風險。

```
authorizeHttpRequests(a -> a
    .requestMatchers("/api/auth/login", "/api/auth/refresh",
        "/api/auth/logout").permitAll()
    .anyRequest().authenticated())
```

JwtDecoder 驗證簽章、issuer 與 token_type，JwtAuthenticationConverter 把 role claim 轉成 ROLE_OWNER 或 ROLE_EMPLOYEE。密碼使用 BCrypt，不保存明文；JWT secret 從環境設定取得；CORS 只允許設定的前端 origin。

6. 國定假日同步與容錯

HolidayCalendarInitializer implements

ApplicationRunner，在應用程式啟動時取得新北市政府資料，轉成 calendar_days。若外部 API 失敗，程式保留既有資料並補齊缺少日期，至少讓週末規則仍可工作。這是「外部依賴失敗不應讓核心功能完全不可用」的實作。

面試可說：業務層只依賴內部 CalendarDay，不直接依賴外部 API，降低耦合，也讓測試可以用 fake client 或固定 Clock。

7. 測試與面試回答

問題	回答方向
為什麼需要 transaction？	避免重新提交班表時，刪除與新增中間留下半套資料，也控制容量檢查的競態。
為什麼前端 disabled 不夠？	前端可被繞過，後端與資料庫才是可信邊界。
為什麼 Flyway？	schema 變更有版本、有順序，環境能重現。
如何擴充審核流程？	新增 schedule status、審核 endpoint，保留 service 交易邊界與角色授權。

練習：新增「員工取消單日班表」API，思考是否仍要限制只能操作次月、是否要檢查身份、以及刪除後如何回傳最新月曆。